

## AN TOÀN THÔNG TIN (INSE330380)

# CHƯƠNG III ĐIỀU KHIỂN TRUY CẬP (Access control)

Ths. ĐỖ MINH HẬU

- ☐ Giới thiệu về kiểm soát truy cập
- ☐ Cấu trúc kiểm soát truy cập
- ☐ Danh sách ACL và Khả năng
- ☐ Quản trị và tổng hợp các cấu trúc kiểm soát truy cập
- ☐ Các mô hình Access Control: MAC, DAC, RBAC, ABAC
- ☐ ACL trong Linux
- ☐ ACL trong Windows

- ❑ Authentication – Authorization – Accounting
- ❑ AAA đề cập đến một tập hợp các quy trình và dịch vụ nhằm đảm bảo an toàn an ninh thông tin trên môi trường mạng. Mỗi thành phần trong AAA có một vai trò cụ thể trong việc đảm bảo tính an toàn
- ❑ Điều khiển truy xuất – Access Control (hoặc Authorization) được sử dụng để kiểm soát quyền truy cập vào hệ thống thông tin dựa vào các quyền đã được gán (Authorization) cho các người dùng khi sử dụng tài nguyên trong hệ thống



- ❑ Sau khi người dùng được xác thực, họ sẽ được cấp quyền truy cập và quyền phù hợp tùy thuộc vào danh tính của họ.
- ❑ Kiểm soát truy cập bao gồm:
  - Chỉ định người dùng quyền thích hợp để truy cập tệp và tài nguyên
  - Cho phép người dùng được xác thực đăng nhập vào hệ thống được sử dụng tài nguyên như theo chỉ định trước đó

- ❑ Trình giám sát tham chiếu (Reference Monitor): cơ chế (mô hình) bắt buộc mọi truy cập từ Subject đến Object phải được kiểm tra và quyết định allow/deny theo chính sách.
- ❑ Nhân bảo mật (security kernel) phần lõi tin cậy (thuộc TCB) hiện thực reference monitor và sử dụng cơ chế OS + phần cứng để đảm bảo: không bị vượt qua, không bị can thiệp, và có thể kiểm chứng



- ❑ Kiểm soát truy cập theo chiều dọc: là các cơ chế hạn chế quyền truy cập vào chức năng quan trọng đối với những loại người dùng cụ thể.
  - Ví dụ: quản trị viên có thể sửa đổi hoặc xóa bất kỳ tài khoản nào của người dùng, trong khi người dùng thông thường không có quyền truy cập vào các hành động này.
- ❑ Kiểm soát truy cập theo chiều ngang: là các cơ chế hạn chế quyền truy cập vào tài nguyên của những người dùng cụ thể.
  - Ví dụ: một ứng dụng ngân hàng sẽ cho phép người dùng xem các giao dịch và thực hiện thanh toán từ tài khoản của chính họ chứ không phải tài khoản của người dùng nào khác.

- ❑ Kiểm soát truy cập phụ thuộc vào ngữ cảnh: hạn chế quyền truy cập vào chức năng và tài nguyên dựa trên trạng thái của ứng dụng hoặc sự tương tác của người dùng với
  - Ví dụ: một trang web bán lẻ có thể ngăn người dùng sửa đổi nội dung giỏ hàng của họ sau khi họ đã thanh toán.

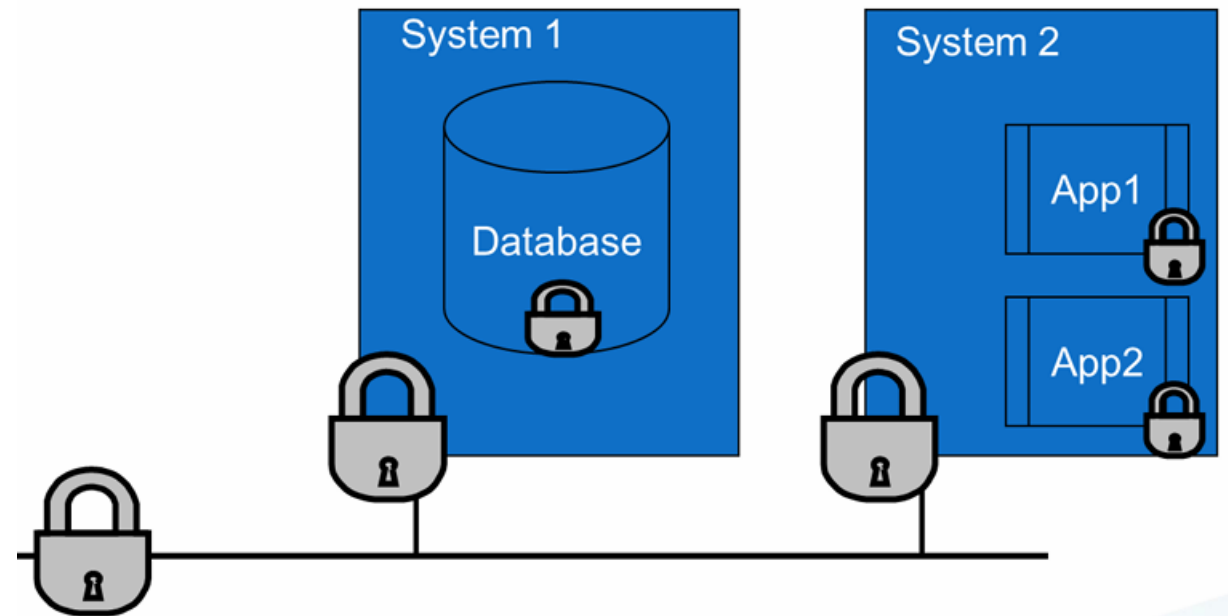


- ❑ Lỗi hỏng kiểm soát truy cập tồn tại khi người dùng có thể truy cập tài nguyên hoặc thực hiện các hành động mà lẽ ra họ không thể thực hiện được.
- ❑ Leo thang đặc quyền theo chiều dọc xảy ra nếu người dùng có thể có quyền truy cập cao hơn. Ví dụ: nếu người dùng không phải quản trị viên có thể có quyền truy cập vào trang quản trị nơi họ có thể xóa tài khoản người dùng.
- ❑ Leo thang đặc quyền theo chiều ngang: Xảy ra nếu người dùng có thể có quyền truy cập vào các tài nguyên thuộc về người dùng khác, thay vì tài nguyên thuộc loại đó của chính họ. Ví dụ: nếu một nhân viên có thể truy cập hồ sơ của các nhân viên khác cũng như của chính họ



| Level       | Subject      | Action            | Guard                 | Protected System |
|-------------|--------------|-------------------|-----------------------|------------------|
| Hardware    | OS Process   | Read memory       | CPU                   | CPU and Memory   |
| Network     | Host         | Send packets      | Firewall              | Intranet         |
| Database    | User         | SELECT query      | DBMS                  | User database    |
| OS          | User         | Open file         | OS Kernel             | Filesystem       |
| OS          | Java Program | Open file         | Java Security Manager | Filesystem       |
| Application | User         | Read patient file | Application code      | Application data |

- ❑ Network access: Virtual Private Network
- ❑ Computer access: login/password, MAC
- ❑ Database access: permissions, DAC, RBAC
- ❑ Application access: permissions, RBAC



- ☐ Thiết lập các quy tắc tiếp cận nguồn thông tin
- ☐ Tạo/duy trì hồ sơ người dùng
- ☐ Phân bổ ID người dùng yêu cầu xác thực (mỗi người, không phải nhóm)
- ☐ Thông báo cho người dùng về việc sử dụng và truy cập hợp lệ trước và sau khi đăng nhập
- ☐ Đảm bảo trách nhiệm giải trình và khả năng kiểm toán bằng cách ghi nhật ký hoạt động của người dùng
- ☐ Ghi lại sự kiện
- ☐ Báo cáo cấu hình và nhật ký kiểm soát truy cập

Được giới thiệu bởi Lampson (1972) và được mở rộng bởi Harrison, Ruzzo và Ullman (1976)

**Ma trận kiểm soát truy cập (ACM- Access Control Matrix )**

- ☐ Tóm tắt trạng thái liên quan đến kiểm soát truy cập.
- ☐ Các hàng tương ứng với người dùng/chủ thể/ nhóm
- ☐ Các cột tương ứng với các tài nguyên cần được bảo vệ.
- ☐ ACM xác định ai có thể truy cập những gì. ACM [U,O] xác định quyền truy cập mà người dùng U có đối với đối tượng O

| Object<br>Subject | File 1 | File 2 | File 3 | File 4 |
|-------------------|--------|--------|--------|--------|
| User 1            | Read   | Write  | Own    | -      |
| User 2            | Write  | Own    | -      | -      |
| User 3            | Own    | -      | -      | Read   |
| User 4            | Read   | Read   | Read   | Own    |

- ❑ Công thức trừu tượng của kiểm soát truy cập không phù hợp để thực hiện trực tiếp
  - Ma trận có thể cực kỳ thưa thớt và do đó việc triển khai không hiệu quả
  - Việc quản lý ma trận có thể cực kỳ khó khăn nếu có 10000 tệp và 100 người dùng (kết quả là 1000000 mục nhập ma trận)
- ❑ Giải pháp ACM: Phân tách ma trận để dễ dàng lưu trữ và truy xuất và biểu diễn các thành phần này bằng cách sử dụng các khái niệm biểu thức
  - Danh sách điều khiển truy xuất: Access control lists (ACL)
  - Danh sách năng lực- Capability lists

## ❑ Danh sách kiểm soát truy cập tập trung vào các Object

- Thường được triển khai ở cấp hệ điều hành , Windows NT sử dụng ACL
- Một ACL được lưu trữ ở phần đáng tin cậy của hệ thống

## ❑ ACL tương ứng với một cột trong ma trận kiểm soát truy cập

- Ví dụ: [a.out: (jason, {r,w,x}), (mick, {r,x})]
- Trình giám sát tham chiếu sử dụng ACL kiểm tra tính hợp lệ của yêu cầu (jason, a.out,

r)

|       | trash | a.out   | allfiles.txt |
|-------|-------|---------|--------------|
| jason | {r,w} | {r,w,x} | {r,w}        |
| mick  |       | {r,x}   | {r}          |

❑ Danh sách khả năng tương ứng với một hàng trong ma trận kiểm soát truy cập

❑ Ví dụ:

[jason: (trash, {r,w}), (a.out, {r,w,x}), (allfiles.txt, {r,w})]

❑ Trình giám sát tham chiếu sẽ kiểm tra tính hợp lệ của yêu cầu (jason, a.out, r)

|       | trash | a.out   | allfiles.txt |
|-------|-------|---------|--------------|
| jason | {r,w} | {r,w,x} | {r,w}        |
| mick  |       | {r,x}   | {r}          |

❑ Các ứng dụng CSDL: sử dụng danh sách các khả năng để thực hiện truy cập vào các bảng và truy vấn



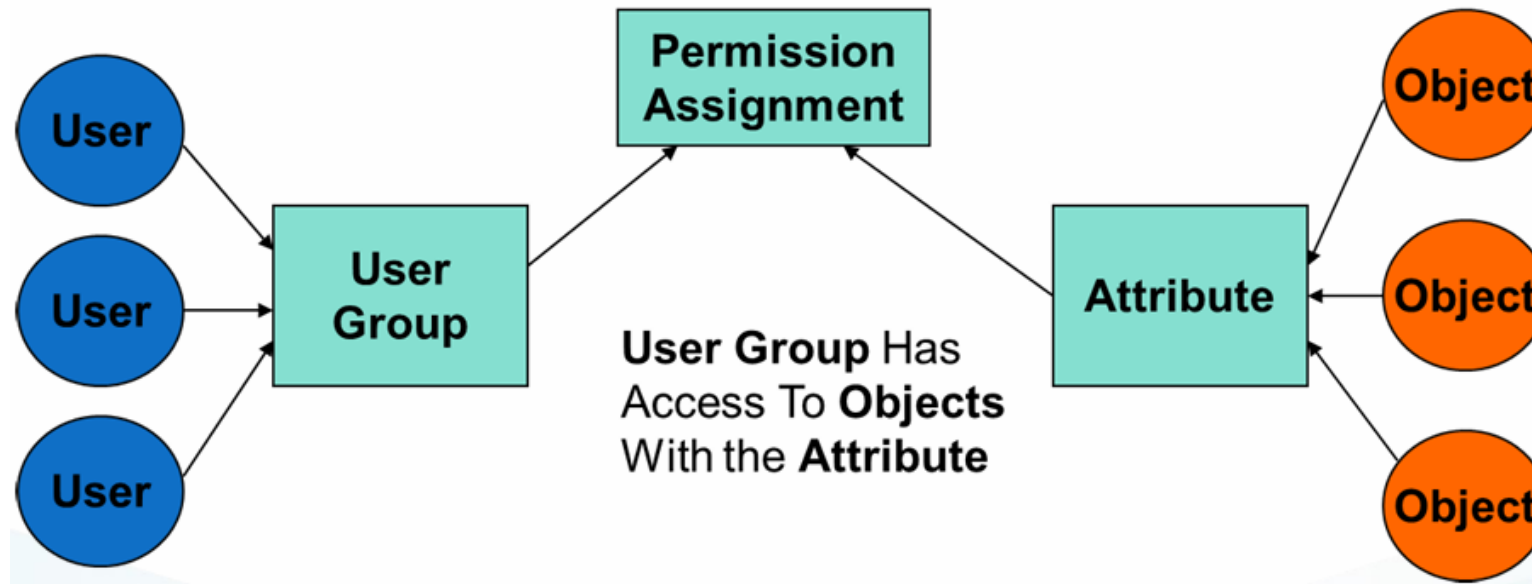
## □ Nhiệm vụ bao gồm

- Tạo các objects và subjects mới.
- Xóa các objects và subjects
- Thay đổi các mục trong ma trận kiểm soát truy cập (thay đổi các mục trong ACL và danh sách các khả năng)

- ❑ Việc quản lý cấu trúc kiểm soát truy cập là cực kỳ tốn nhiều thời gian, phức tạp và dễ bị lỗi
- ❑ Để đơn giản hóa Việc quản lý: Các cấu trúc AC tổng hợp các objects và subjects:
  - User groups
  - Roles
  - Procedures (policies)
  - Data types

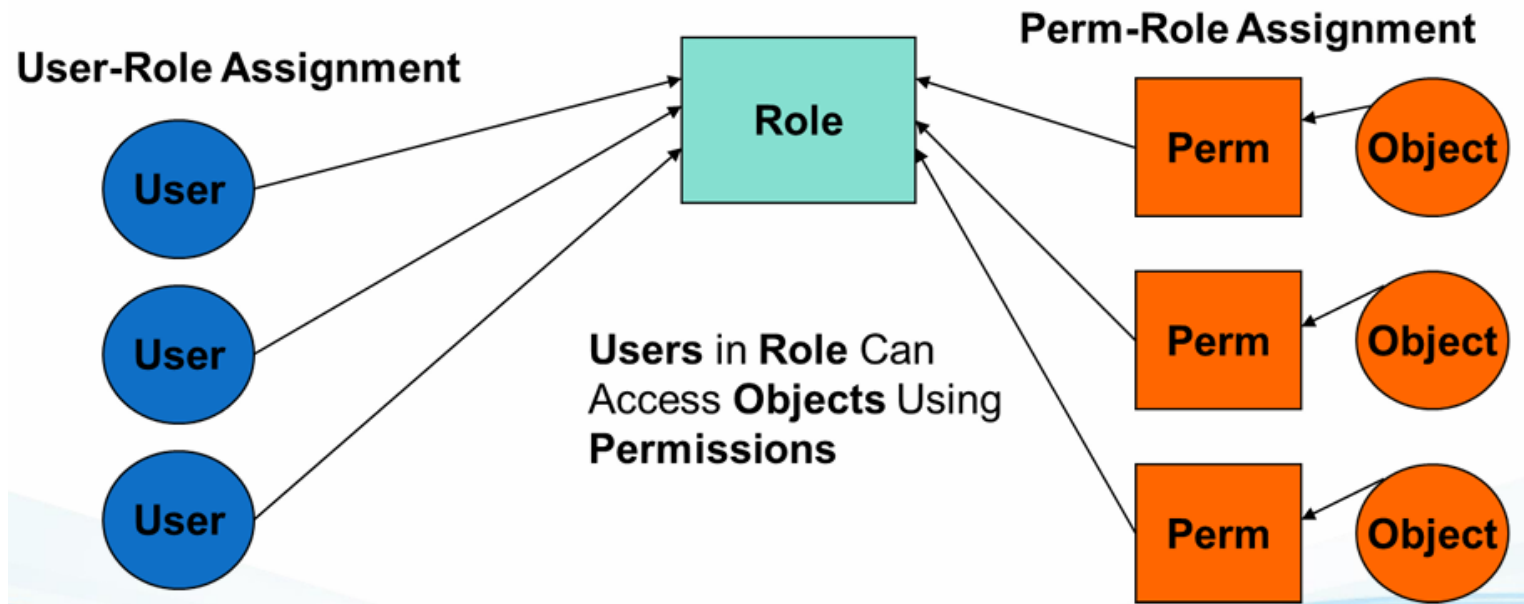
## □ Groups

- Trong UNIX ba nhóm được liên kết với từng object: Owner, Group (owner), Others
- Trong VMS có bốn nhóm: Owner, Group, World, System



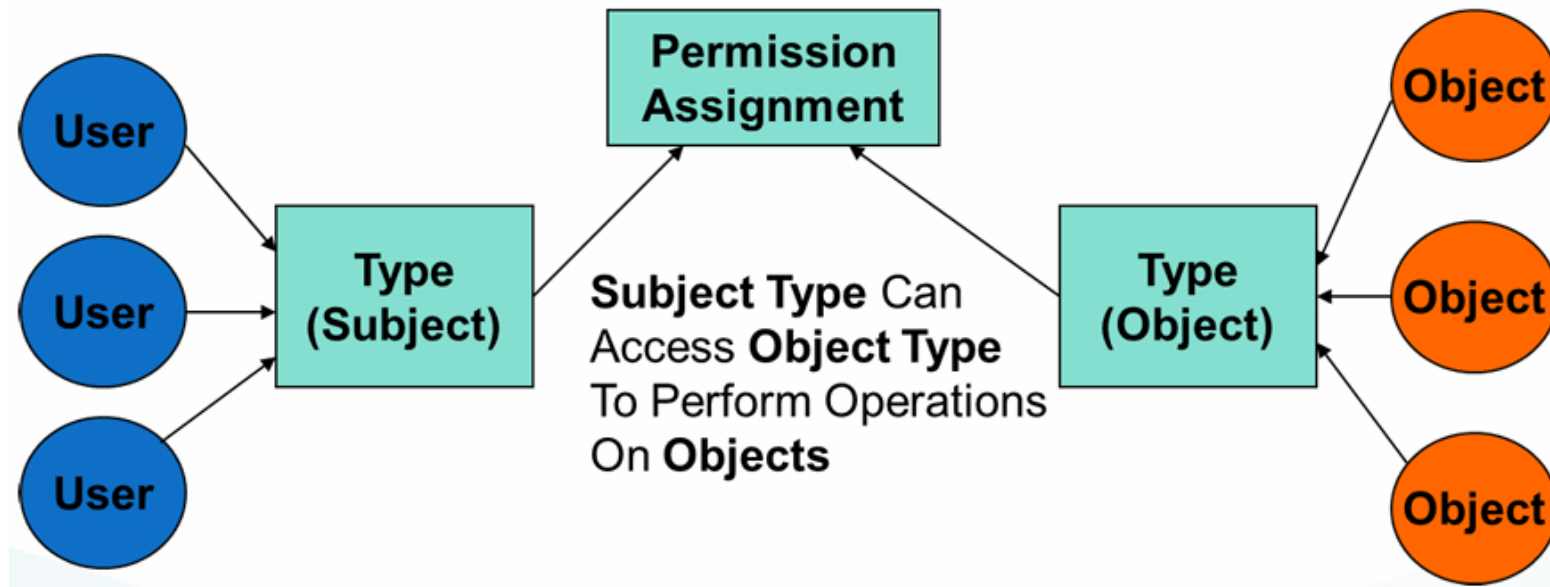
## ❑ Vai trò:

- Quyền được gán cho vai trò
- Người dùng được gán các vai trò
- Vai trò (thường) được sắp xếp theo thứ bậc



## □ Kiểu dữ liệu:

- Là một tập hợp các đối tượng có cùng cấu trúc (ví dụ: tài khoản ngân hàng)
- Ta xác định các hoạt động truy cập (thủ tục hoặc quyền) trên một loại dữ liệu



- ❑ Kiểm soát truy cập bắt buộc (MAC- Mandatory access control): hệ thống quyết định chính xác ai có quyền truy cập vào tài nguyên nào trong hệ thống.
- ❑ Kiểm soát truy cập tùy ý (DAC- Discretionary access control ): người dùng được ủy quyền xác định người dùng nào khác có thể truy cập tệp hoặc tài nguyên khác mà họ tạo.
- ❑ Kiểm soát truy cập dựa trên vai trò (RBAC- Role-based access control ): MAC đặc biệt hệ thống quyết định chính xác người dùng nào được phép truy cập tài nguyên nào—nhưng hệ thống thực hiện việc này theo một cách đặc biệt.

- ❑ Kiểm soát truy cập dựa trên thuộc tính (ABAC- Attribute-based access control ): Kiểm soát quyền truy cập dựa trên thuộc tính của người dùng, tài nguyên được truy cập và điều kiện môi trường hiện tại.
- ❑ Kiểm soát truy cập vật lý: Khóa, hàng rào, sinh trắc học, huy hiệu, chìa khóa



MAC

| Role            | Resource | Privilege            |
|-----------------|----------|----------------------|
| Backup Operator | /home/*  | Read                 |
| Administrator   | /*       | Read, write, execute |

DAC

| User  | Resource                      | Privilege            |
|-------|-------------------------------|----------------------|
| Alice | /home/Alice/*                 | Read, write, execute |
| Bob   | /home/Bob/*                   | Read, write, execute |
| *     | /home/Alice/product_specs.txt | Read                 |

RBAC

| Role            | Resource                      | Privilege            |
|-----------------|-------------------------------|----------------------|
| Backup Operator | /home/*                       | Read                 |
| Administrator   | /*                            | Read, write, execute |
| Programmer      | /home/Alice/product_specs.txt | Read                 |

- ❑ DAC: chủ sở hữu tài nguyên quyết định cách chia sẻ tài nguyên đó cho người dùng khác
  - Có mức độ linh hoạt cao
  - Không áp đặt quyền kiểm soát cách thức truyền bá thông tin
- ❑ Hạn chế của DAC:
  - Không thể kiểm soát nếu một người nào đó bạn chia sẻ một tệp sẽ không chia sẻ thêm dữ liệu chứa trong đó
  - Không thể kiểm soát "luồng thông tin"

- ☐ Trong nhiều tổ chức, người dùng không nhận được quyết định cách chia sẻ loại dữ liệu nhất định
- ☐ Thông thường người sử dụng lao động có thể chỉ định cách chia sẻ các loại dữ liệu nhạy cảm khác

❑ Chính sách MAC đảm bảo mức độ bảo vệ cao:

- Cứng rắn
- Kiểm soát và ngăn chặn luồng thông tin bất hợp pháp

❑ MAC hạn chế quyền truy cập của chủ thể vào đối tượng dựa trên chính sách toàn hệ thống, từ chối người dùng toàn quyền kiểm soát quyền truy cập vào tài nguyên mà họ tạo.

- Chính sách bảo mật hệ thống do quản trị viên đặt

❑ MAC sử dụng trong lĩnh vực quân sự và tình báo:

- Dữ liệu có mức độ phân loại liên quan và người dùng được minh bạch ở các cấp khác nhau như: Top secret, secret, confidential
- Giới hạn về người có thể truy cập dữ liệu ở một mức độ nhất định
- Người dùng chỉ minh bạch ở mức secret không thể truy cập dữ liệu Top secret
- Còn được gọi là bảo mật đa cấp (MLS- multilevel security)

- ❑ **Multilevel security:** là một mô hình máy được sử dụng để thực thi kiểm soát truy cập vào các ứng dụng của chính phủ và quân sự, được phát triển bởi David Elliott Bell và Leonard J. LaPadula.
- ❑ **Multi-level security- Khả năng của một hệ thống máy tính:**
  - Mang thông tin có độ nhạy cảm khác nhau (tức là thông tin được phân loại ở các cấp độ bảo mật khác nhau),
  - Cho phép người dùng truy cập đồng thời với các thông tin bảo mật và nhu cầu cần biết khác nhau
  - Ngăn chặn người dùng có được quyền truy cập vào thông tin mà họ ko được phép.
  - Sử dụng làm thuộc tính của cả Subjects và Objects

## ❑ Labels: Yêu cầu chính để triển khai MAC

- Chỉ ra độ nhạy / loại dữ liệu hoặc các yêu cầu về rò rỉ / cần phải biết của người sử dụng
- TCB kết hợp Label với mỗi người dùng với đối tượng và kiểm tra chúng khi yêu cầu truy cập được thực hiện: Cần gắn Label để có thể so sánh chúng
- Bản chất chính xác của Label phụ thuộc vào loại mô hình / chính sách được thực hiện
- Các mô hình DoD bao gồm mức phân loại / rò rỉ và một ngăn trong nhãn
- Các chính sách thương mại khác nhau nhưng sử dụng các Label để tránh xung đột lợi ích, phân chia nhiệm vụ vv



□ Label = (sensitivity level, Compartments)

- Ví dụ: Ta hãy xem xét các tài liệu có độ nhạy cao có thông tin về các kho vũ khí khác nhau.

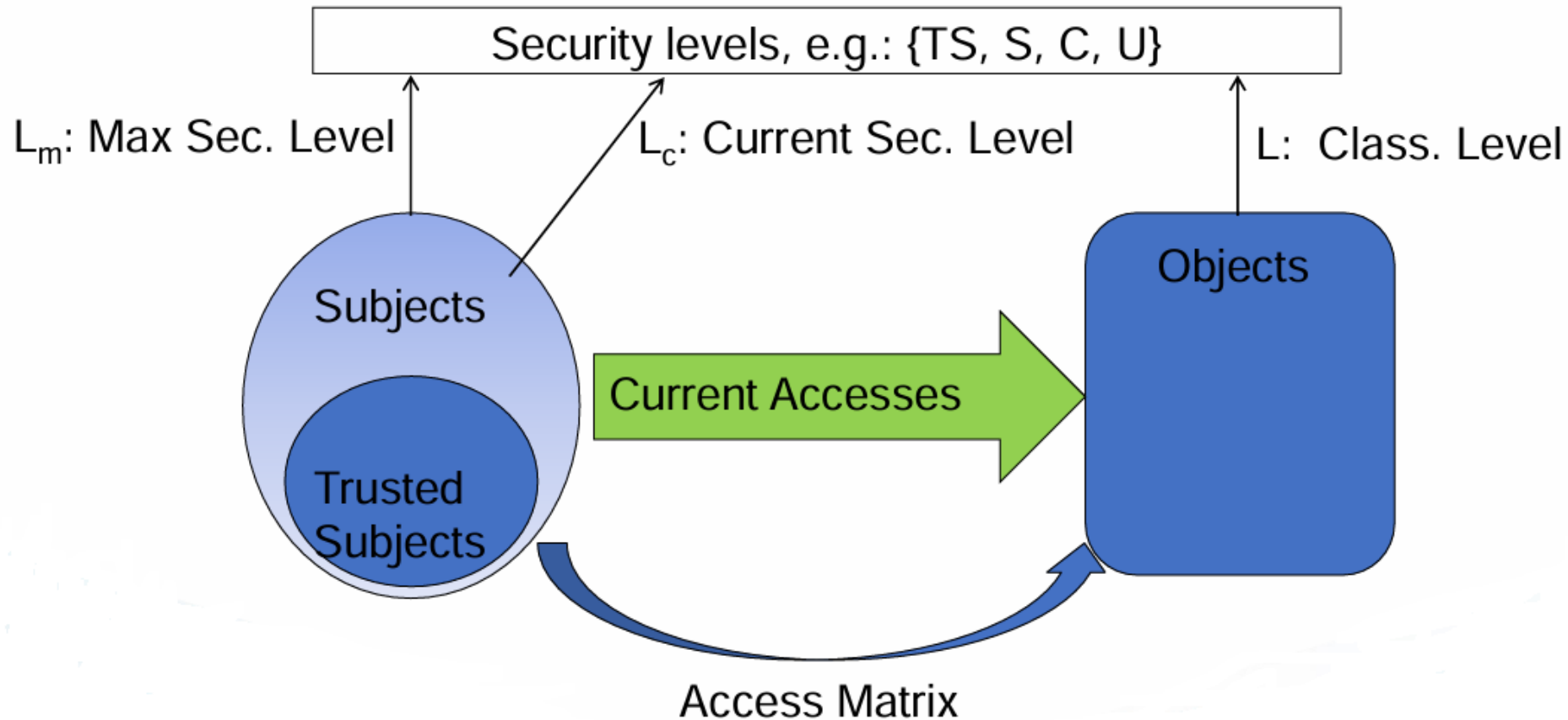
L1 = (TS, {nuclear, chemical})

L2 = (S, {nuclear, conventional})

- ❑ Là Mô hình MAC đạt được bảo mật đa cấp (Multilevel security)
- ❑ Giới thiệu vào 1973, khi lực lượng Không quân lo ngại về an ninh trong các hệ thống chia sẻ thời gian
  - Nhiều lỗi hệ điều hành
  - Sử dụng sai mục đích
  - Mô hình Bell-La Padula được sử dụng để thực thi kiểm soát truy cập vào các ứng dụng của chính phủ và quân sự.

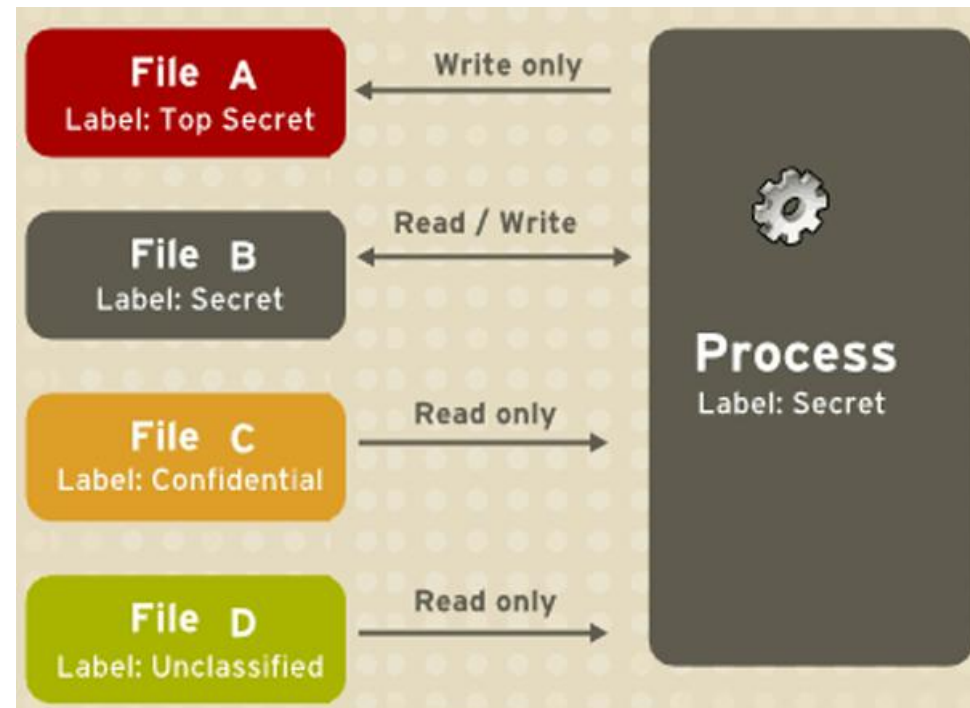
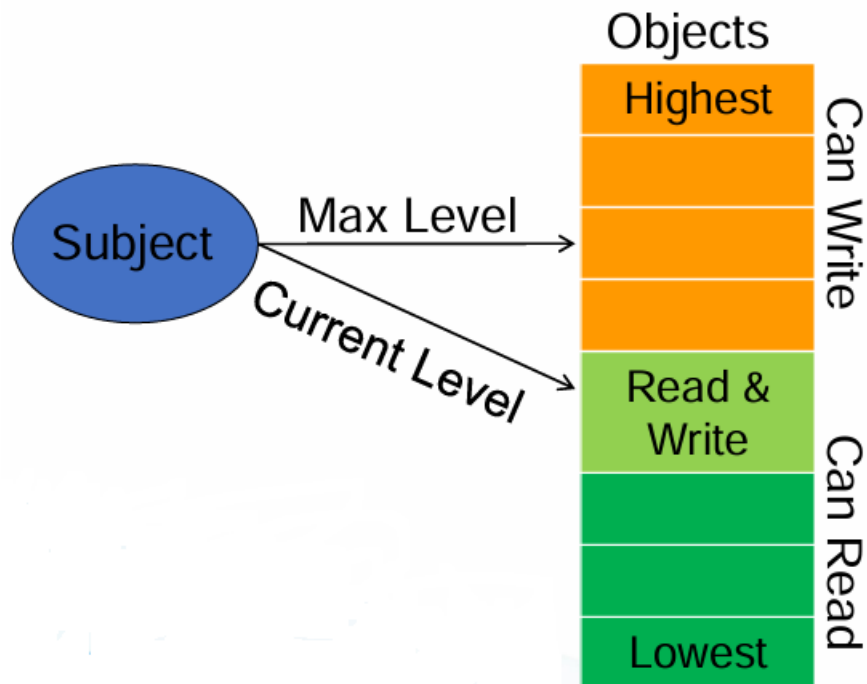
- ❑ Các mô hình Bell-LaPadula tập trung vào bảo mật dữ liệu và kiểm soát truy cập thông tin mật
- ❑ Mục tiêu chính: Cho phép một người chính thức chứng minh rằng hệ thống máy tính có thể xử lý thông tin mật một cách an toàn.

## Các thành phần của mô hình: Subjects và Objects



Minh họa các chính sách của mô hình:

- Read-down rule (simple security property)
- Write-up rule (star property)



Biba là dạng BLP kép.

- ☐ Tập trung vào tính toàn vẹn hơn là tính bảo mật như của BLP
- ☐ Thông tin có tính toàn vẹn thấp sẽ không bao giờ được đưa vào các tài liệu có tính toàn vẹn cao
- ☐ Gọi  $I(O)$  biểu thị tính toàn vẹn của Object  $O$  và  $I(S)$  biểu thị tính toàn vẹn của Subject  $S$

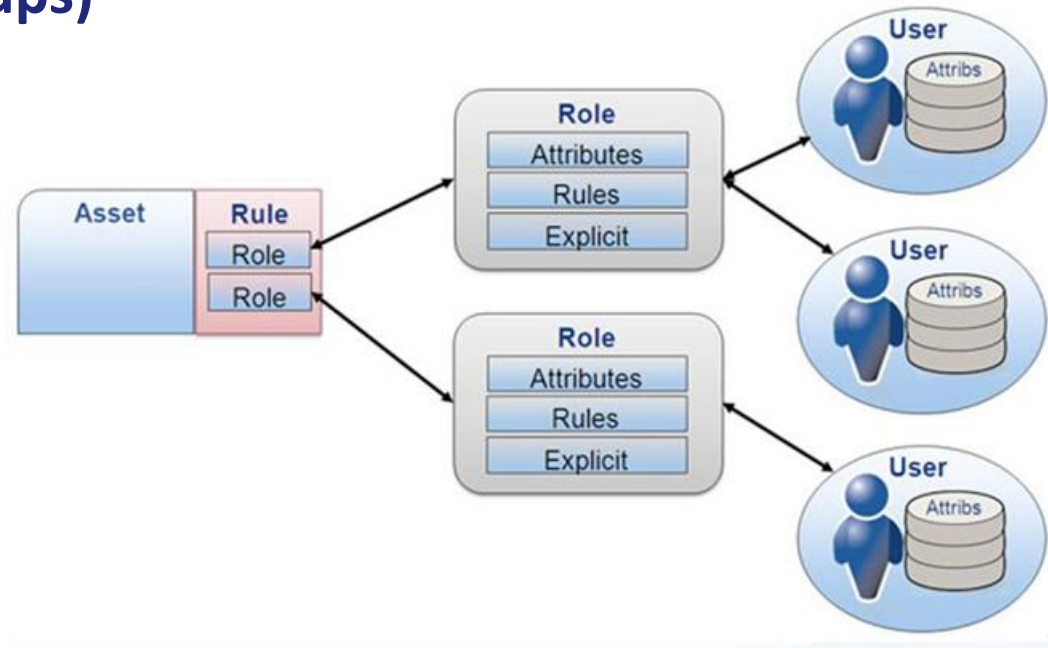
□ Biba gồm:

- Quy tắc truy cập Viết: S có thể viết O khi và chỉ khi  $I(O) \leq I(S)$  (nếu S viết O thì tính toàn vẹn của O  $\leq$  tính toàn vẹn của S)
- Mô hình Biba: S có thể đọc O khi và chỉ khi  $I(S) \leq I(O)$  (nếu S đọc O thì tính toàn vẹn của S  $\leq$  tính toàn vẹn của O)

□ Thông thường, hãy thay thế Mô hình của Biba bằng Chính sách: Nếu S đọc O thì  $I(S) = \min(I(S), I(O))$



- ❑ Hệ thống quyết định chính xác người dùng nào được phép truy cập tài nguyên nào - nhưng hệ thống thực hiện việc này theo một cách đặc biệt
- ❑ RBAC được triển khai trong một số hệ thống:
  - Window NT (as global and local groups)
  - IBM's OS/400
  - Oracle 8 onwards
  - .NET framework



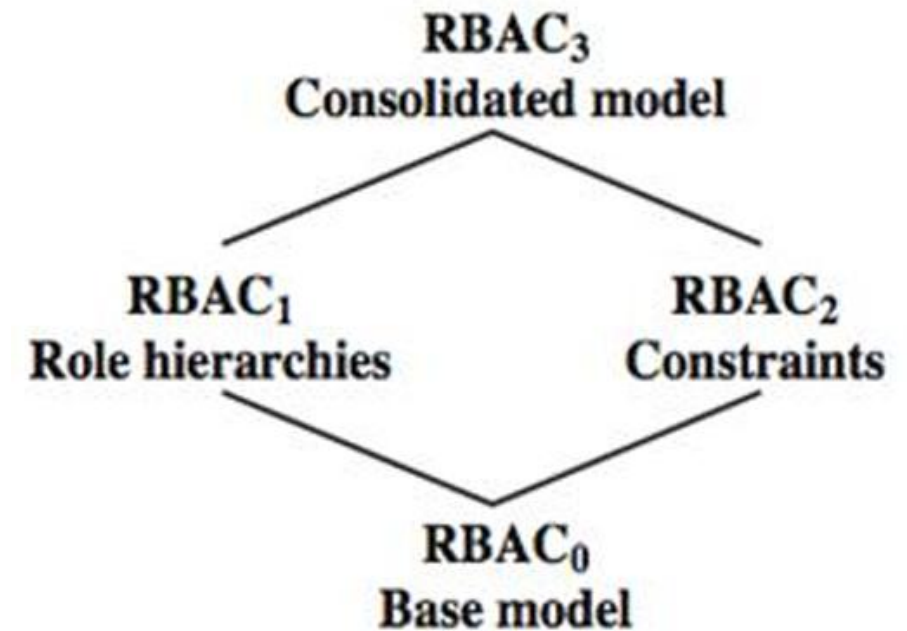
## 2 ma trận

|       | $R_1$ | $R_2$ | ... | $R_n$ |
|-------|-------|-------|-----|-------|
| $U_1$ | ×     |       |     |       |
| $U_2$ | ×     |       |     |       |
| $U_3$ |       | ×     |     | ×     |
| $U_4$ |       |       |     | ×     |
| $U_5$ |       |       |     | ×     |
| $U_6$ |       |       |     | ×     |
| ...   |       |       |     |       |
| $U_m$ | ×     |       |     |       |

|       |                | OBJECTS        |                |                |                |                |                |                |                |                |
|-------|----------------|----------------|----------------|----------------|----------------|----------------|----------------|----------------|----------------|----------------|
|       |                | R <sub>1</sub> | R <sub>2</sub> | R <sub>n</sub> | F <sub>1</sub> | F <sub>2</sub> | P <sub>1</sub> | P <sub>2</sub> | D <sub>1</sub> | D <sub>2</sub> |
| ROLES | R <sub>1</sub> | control        | owner          | owner control  | read *         | read owner     | wakeup         | wakeup         | seek           | owner          |
|       | R <sub>2</sub> |                | control        |                | write *        | execute        |                |                | owner          | seek *         |
|       | •              |                |                |                |                |                |                |                |                |                |
|       | •              |                |                |                |                |                |                |                |                |                |
|       | R <sub>n</sub> |                |                | control        |                | write          | stop           |                |                |                |

## Mối quan hệ

- ❑ RBAC0 chứa chức năng tối thiểu cho hệ thống RBAC.
- ❑ RBAC1 bao gồm chức năng RBAC0 và vai trò kế thừa quyền từ vai trò khác
- ❑ RBAC2 bao gồm RBAC0 và thêm các ràng buộc, hạn chế cách thức sử dụng các thành phần của hệ thống RBAC.
- ❑ RBAC3 bao gồm RBAC0 cộng với chức năng bổ sung của cả RBAC1 và RBAC2.



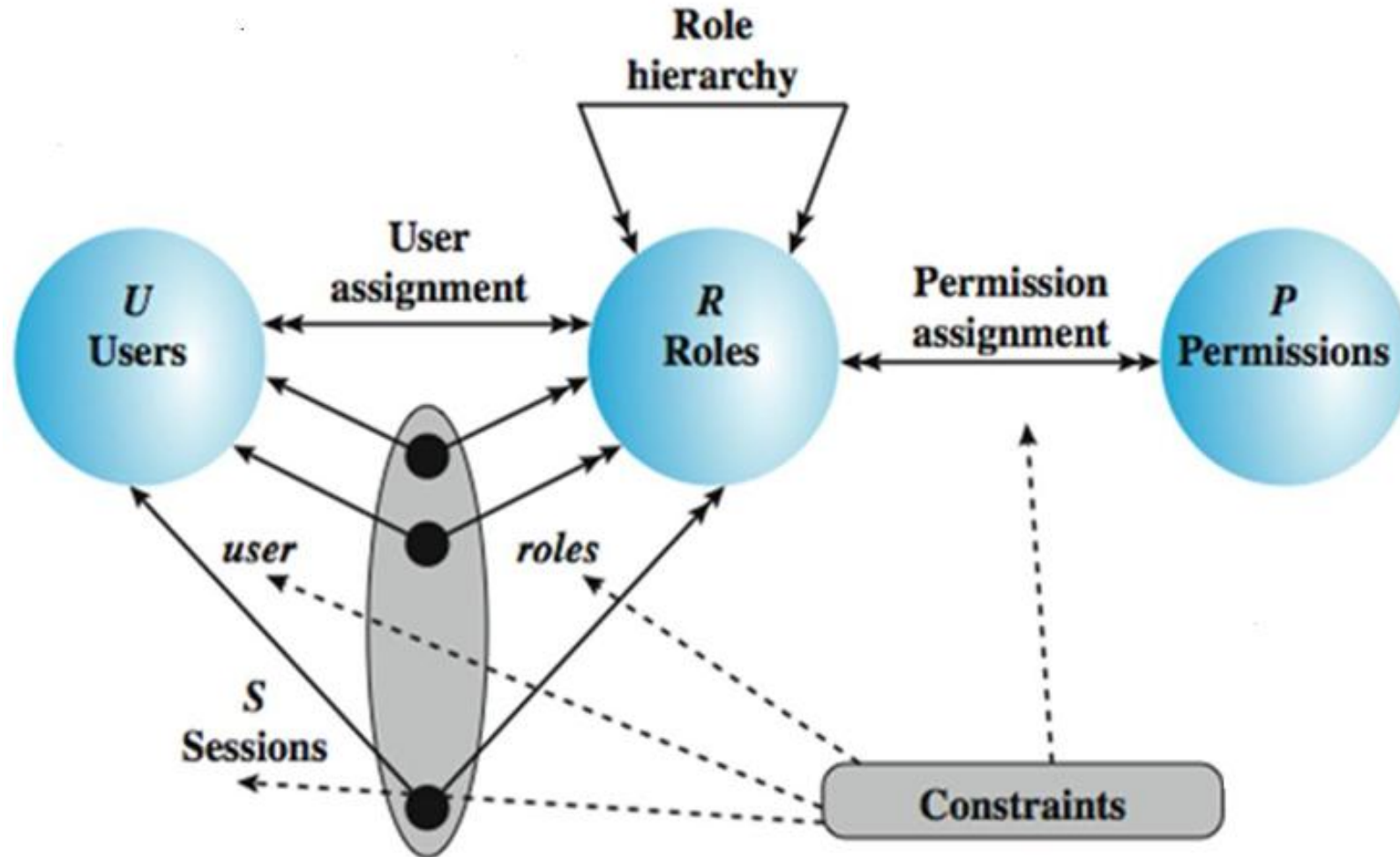
## ❑ Phân cấp vai trò- Role hierarchy:

- Role có thể xếp theo cấp bậc. Role cấp cao thừa hưởng quyền của role cấp thấp.
- Cấp bậc trong công ty không nhất thiết giống cấp bậc quyền. Sếp không phải lúc nào cũng cần (hoặc được phép) có mọi quyền của nhân viên.
- Cơ cấu tổ chức chỉ để tham khảo, thiết kế role phải theo công việc cần làm và an toàn.

## ❑ Ràng buộc –Constraints:

- Ràng buộc = luật an toàn trong RBAC, để tránh cấp quyền sai hoặc lạm quyền.
- Luật này phải đúng mọi lúc, mọi trường hợp (dù ai được gán role nào, đăng nhập phiên nào...).
- Một số ràng buộc hay dùng (để quản lý nhất):
  - Loại trừ lẫn nhau: không được có 2 role “xung đột” cùng lúc.(VD: người tạo đơn ≠ người duyệt đơn)
  - Tách biệt nhiệm vụ (SoD): chia việc quan trọng cho nhiều người. (VD: nhập và duyệt phải là 2 người khác)
  - Giới hạn quyền lực: giới hạn số người có role nhạy cảm / cần điều kiện mới được có role. (VD: role Admin tối đa 2 người)

## Hệ thống RBAC chứa bốn loại thực thể





Hệ thống RBAC chứa bốn loại thực thể

- ☐ User: Một cá nhân có quyền truy cập vào hệ thống và ID kèm theo.
- ☐ Role: vai trò được đặt tên trong tổ chức kiểm soát hệ thống, liên kết với mô tả về thẩm quyền và trách nhiệm nhận được đối với vai trò này và đối với bất kỳ User nào đảm nhiệm vai trò này.
- ☐ Permission: sự chấp thuận của một phương thức tiếp cận cụ thể của một hoặc nhiều đối tượng.
- ☐ Session: Lập ánh xạ giữa User và tập con được kích hoạt của tập các vai trò mà User được chỉ định(quyền truy cập, đặc quyền và ủy quyền.)

## Sự cần thiết của các mô hình tổng hợp (RBAC)

- Trừu tượng hóa cho người dùng, quyền, ràng buộc, quản trị
- Tập hợp kiểm soát truy cập tự nhiên – dựa trên vai trò tổ chức.
- Kiểm soát trung tâm và duy trì quyền truy cập
- Đủ linh hoạt để thực thi đặc quyền tối thiểu, phân chia nhiệm vụ, v.v



## Lợi ích của RBAC:

- Chỉ cần chỉ định người dùng và quyền cho các vai trò
- Có thể sử dụng thừa kế trong phân cấp vai trò để giảm số lượng các thao tác gán theo yêu cầu
- Đơn giản hóa việc quản trị

- ❑ NIST (Ferraiolo et al., 1992-2000)
- ❑ RBAC96 (Sandhu et al., 1996)
- ❑ ARBAC97 (Sandhu et al., 1997-99)
- ❑ OASIS (Hayton et al., 1996-2001)
- ❑ Role Graph model (Nyanchama and Osborn, 1995-2001)
- ❑ Unified RBAC96 NIST model (Ferraiolo, Sandhu et al., 2001)

□ ABAC là một mô hình quản lý truy cập:

- Quyền truy cập sẽ được cấp cho người dùng thông qua việc sử dụng các “chính sách” được cấu thành bởi một hoặc nhiều thuộc tính khác nhau.
- Chính sách là một tập hợp các quy tắc và mối quan hệ chi phối hành vi được phép trong một tổ chức, dựa trên đặc quyền của Subject và cách thức bảo vệ tài nguyên hoặc Object trong điều kiện môi trường cụ thể.

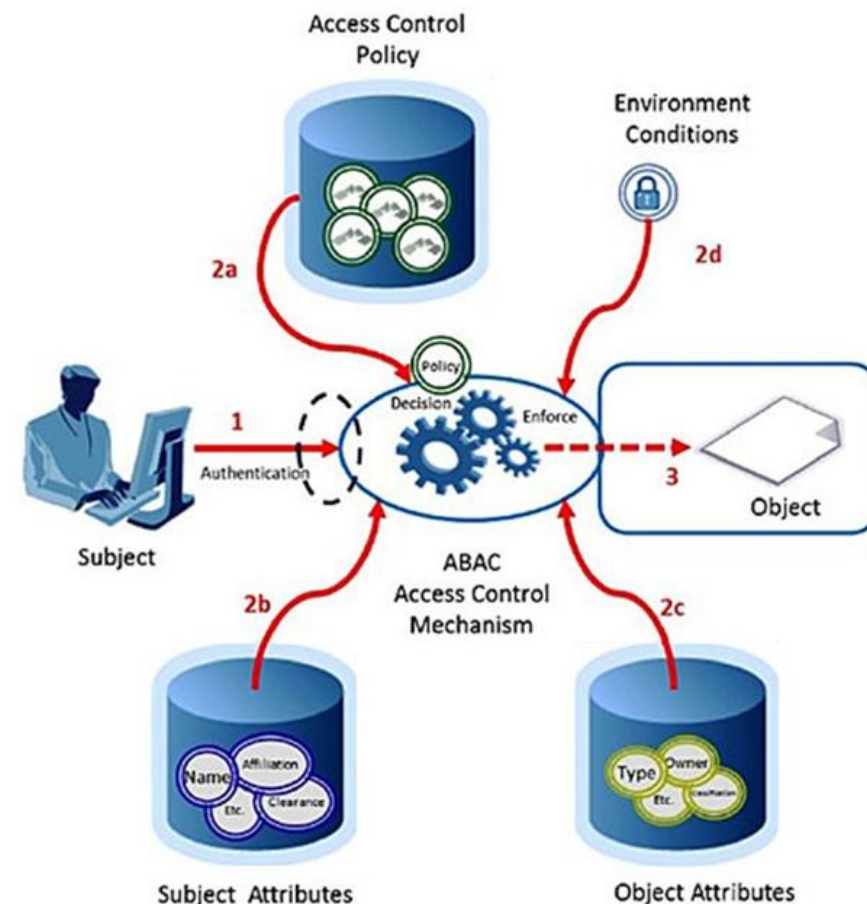
□ Có ba yếu tố chính trong mô hình ABAC:

- Các thuộc tính được xác định cho các thực thể trong cấu hình: subject, object, ..
- Một mô hình chính sách xác định các chính sách ABAC;
- Mô hình kiến trúc áp dụng cho các chính sách thực thi kiểm soát truy cập

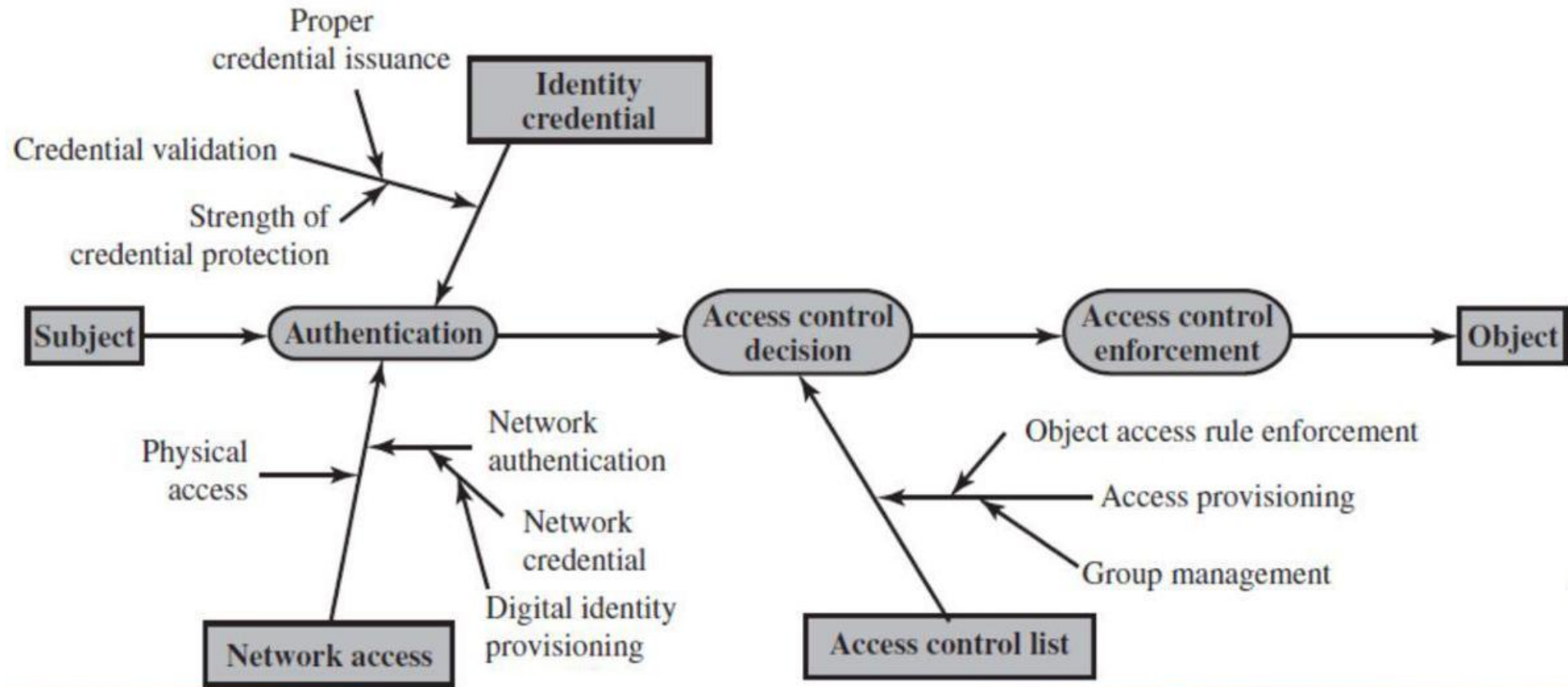
NIST đưa ra kịch bản sau để mô tả hoạt động của ABAC

1. Subject yêu cầu quyền truy cập vào một Object. Yêu cầu này được chuyển đến cơ chế kiểm soát truy cập.

2. Cơ chế AC được điều chỉnh bởi một bộ quy tắc: (2a) được xác định bởi chính sách kiểm soát truy cập được cấu hình sẵn. Dựa trên các quy tắc này, cơ chế AC đánh giá các thuộc tính của Subject (2b), Object (2c) và điều kiện môi trường hiện tại (2d) để xác định quyền.

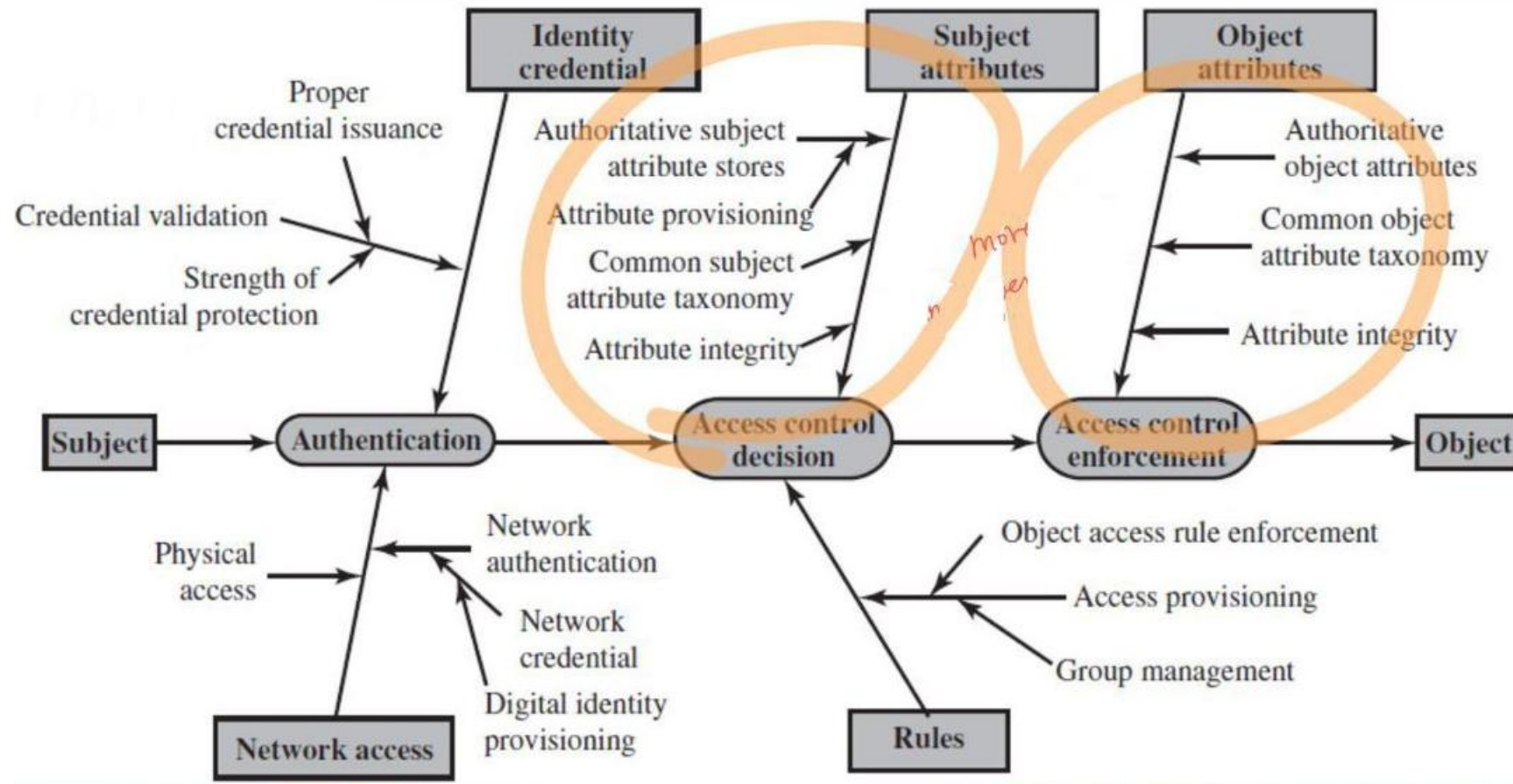


## Chuỗi tin cậy ACL





## Chuỗi tin cậy ACL



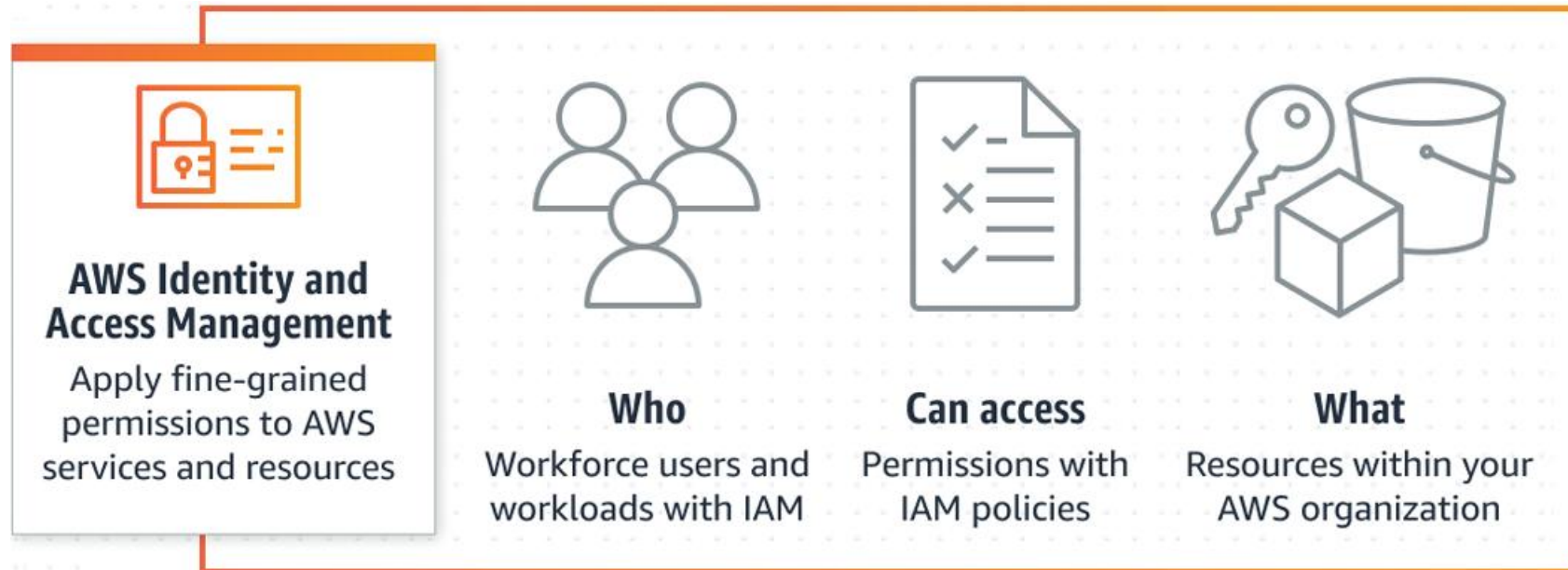


❑ Ưu điểm: việc sử dụng các giá trị thuộc tính đa dạng để tạo ra các “chính sách” linh động. Nhờ những chính sách linh động trên, mô hình ABAC cho phép thực hiện kiểm soát truy cập thông minh theo ngữ cảnh và rủi ro. Qua đó mô hình có thể quản lý việc truy cập tài nguyên chặt chẽ hơn các mô hình access control khác.

Ví dụ: thay vì phải sử dụng các roles với các quyền được định nghĩa sẵn từ đầu như trong mô hình RBAC, ABAC cho phép tạo ra các chính sách linh động dựa trên các thuộc tính thuộc nhiều nhóm khác nhau để đưa ra quyết định phân quyền.

- ❑ **Nhược điểm của mô hình ABAC: phức tạp hơn so với các mô hình khác.**
- ❑ **Mô hình ABAC đã được áp dụng ở trong nhiều dự án công nghệ lớn, tiêu biểu là IAM (Identity and Access Management) của Amazon.**
- ❑ **Arborist – một open source policy được thiết kế dựa trên mô hình ABAC: được dùng giải quyết bài toán phân quyền của hệ thống MASH tại VinBigdata**

**AWS IAM: Quản lý danh tính và truy cập trong bạn có thể chỉ định những cá nhân hoặc thiết bị có thể truy cập các dịch vụ và tài nguyên trong AWS, quản lý tập trung các quyền chi tiết và phân tích truy cập để tinh chỉnh quyền trên AWS.**



- ❑ Arborist là một open source policy engine được viết bởi Đại học Chicago được viết bằng Golang, sử dụng PostgreSQL để lưu trữ dữ liệu.
  - ❑ Arborist đóng vai trò như một dịch vụ quản lý phân quyền cho hệ thống MASH, quản lý các tài nguyên dưới dạng cây phân cấp theo đúng mô hình dữ liệu của MASH
    - MASH là một nền tảng quản lý, phân tích, chia sẻ và tổng hợp thông tin dữ liệu Y sinh
    - Hệ thống sử dụng các công nghệ mới nhất như Kubernetes, Docker, kiến trúc microservices, Kafka, Redis... để giúp cho những nhà nghiên cứu, bác sĩ, chuyên gia có thể truy xuất các thông tin biến dị từ nhiều dự án và nhiều nguồn thông tin khác nhau
    - Mô hình dữ liệu của dự án với gần 100 bảng liên kết theo cấu trúc phân tầng.
- =>MASH đáp ứng mô hình quản lý quyền mạnh mẽ, linh hoạt, dễ sử dụng

□ Arborist định nghĩa các khái niệm chính sau:

- **Action:** là một hành vi được thực hiện của một service.
- **Permission:** là một sự kết hợp giữa action và một số các ràng buộc đi kèm dùng để hạn chế context sử dụng của action
- **Role:** là một tập hợp các permissions
- **Resource:** là dữ liệu cần được quản lý truy cập, được biểu diễn dưới dạng như đường dẫn trong hệ thống cây quản lý file
- **Policy:** là một tập kết hợp giữa các roles và resources, với ý nghĩa là tác nhân với policy A sẽ được phép sử dụng bất cứ roles nào trong policy A lên tất cả các resources trong policy A. Các policies có thể được cấp cho các users hoặc các groups

**Action:**

```
{  
  "service": "fence",  
  "method": "read",  
}
```

**Permission:**

```
"permissions": [  
  {  
    "id": "read",  
    "description": "string",  
    "action": {  
      "service": "fence",  
      "method": "read"  
    },  
    "constrains": [{  
      "not-allow": "Sunday"  
    }]  
  }  
]
```

**Resource:**

```
/projects  
/projects/cancer  
/projects/cancer/samples
```

**• Role**

```
{  
  "id": "read",  
  "description": "string",  
  "permissions": [  
    {  
      "id": "read",  
      "description": "string",  
      "action": {  
        "service": "fence",  
        "method": "read"  
      }  
    }  
  ]  
}
```

**• Policy:**

```
{  
  "id": "policy id",  
  "role_ids": [  
    "read"  
  ],  
  "resource_paths": [  
    "/projects/cancer/samples/sample_01"  
  ]  
}
```



- ❑ Mỗi tệp có một chủ sở hữu, người này có ID người dùng (UID) duy nhất.
- ❑ Có thể truy cập cho chủ sở hữu, nhóm và thế giới.
- ❑ Quyền được đọc, viết, thực thi: read, write, execute (r,w,x)
- ❑ Quyền đặc biệt: quyền cho phép người dùng và nhóm không phải là chủ sở hữu hoặc nhóm của tệp thực thi tệp đó như thể họ là chủ sở hữu, cần dùng các thiết lập
  - SETUID - đặt ID người dùng khi thực thi
  - SETGID - đặt ID nhóm khi thực thi
  - StickyBit - đặt thư mục ở chế độ cố định



❑ **Lệnh gán quyền truy cập:** *chmod*

**Example:** *chmod 4762 myfile* translates to:

*setuid = on*

*setgid = off*

*sticky bit = off*

*user = read + write + execute*

*group = read + write*

*other = write*

## ❑ Set UID, GID, Sticky bit

*chmod u+s = add setuid*

*chmod g-s = remove setgid*

*chmod o+t = add sticky bit*

## ❑ Others:

*chmod a+w = add write to \*all\**

*chmod a-wx = remove write and execute from \*all\**

*chmod -R 755 myfolder*

- ❑ ACL cung cấp khả năng kiểm soát chi tiết hơn về việc người dùng có thể truy cập các thư mục và tệp cụ thể.
- ❑ Bằng cách sử dụng ACL, ta có thể chỉ định cách thức mà mỗi người dùng và nhóm có thể truy cập vào một thư mục hoặc tệp.

- ❑ Các lệnh:

- Hiển thị tên tệp, chủ sở hữu, nhóm và ACL hiện có cho một tệp: **getfacl**
- Đặt ACL của tệp và thư mục: **setfacl -m**

*setfacl -m ugo:u/g\_name:permissions fil/fol\_name*

**Ex:** *setfacl -m u:student04:rw- script00.sh => student04: r, w*

- Xóa các quy tắc trong tệp hoặc thư mục: **setfacl -x**

## □ Commands:

- **List:** *net user, net localgroup*
- **Change the permissions**
- **Testing - quickly start a program as another user:** *runas*
- **Ex,** *runas /User:jack cmd.exe*

- ☐ Cấu trúc kiểm soát truy cập
- ☐ Danh sách ACL và Khả năng
- ☐ Quản trị và tổng hợp các cấu trúc kiểm soát truy cập
- ☐ Các mô hình AC: MAC, DAC, BRAC, ABAC
- ☐ ACL trong Linux
- ☐ ACL trong Windows

# AN TOÀN THÔNG TIN (INSE330380)

## Kết thúc chương 3.1

Ths. ĐỖ MINH HẬU





Trung tâm Học liệu và Dạy học số  
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh  
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh  
[daotaotuxa@hcmute.edu.vn](mailto:daotaotuxa@hcmute.edu.vn)